

Security incident report

Section 1: Identify the network protocol involved in the incident

As we can see in the tcpdump log the layer of the tcp/ip model involved is the application layer as after connecting to the website “yummyrecipesforme” using dns and http requests, both the HTTP protocol and the DNS Protocol are involved, request is initiated with “HTTP: GET / HTTP/1.1”, downloading a malware with the HTTP request, in order to redirect visitors to a malicious website with a new DNS and HTTP request. This ended up in a new dns protocol request in order to connect to the malicious new website “greatrecipesforme”, with malware in it.

Section 2: Document the incident

During the day one of the company employees probably started a brute force attack in order to gain access to the web host and modify the website code. He started a try and error default password input in order to access an administrative account.

We believe this as the administrative account in question can't be accessed now.

After obtaining the login credential, he modified the website code in order to run a javascript function that made website visitors download a malicious file in order to redirect them to a new unsafe website and infect the device connecting.

After temporarily disabling the website, we addressed the incident, running the website in a contained safe sandbox environment and analyzing with tcpdump log what was happening to the website visitors.

The tcpdump logs shows how after establishing a connection with a DNS and HTTP request with the website “yummyrecipesforme”, a data request is performed in order to download a malicious file, who would change the port for a new dns request to a specific IP and redirecting the visitor to the malicious website “greatrecipesforme”, with malware in it.

Section 3: Recommend one remediation for brute force attacks

The most important security strengthening, in order to avoid possible future brute force attacks, is to implement MFA and 2FA verification and stronger passwords for administrative level users to prevent high risk vulnerabilities. Even implementing some password policies in order to change frequently passwords, making complex passwords, and putting limits to how many times a user can attempt to log in before their account is suspended.

Another strong recommendation is to create Security Zones with limitations inside the network for administrative logins, so that normal employees' devices in the network cannot try to login as someone else.

Another good recommendation in order to strengthen the website security is to update the site, using a HTTPS request, which is much safer than the outdated HTTP.